



범죄수사학연구

ISSN 2466-1236

범죄수사학연구

포트스캔 기반 공개출처정보(OSINT) 수집의 기술적 특성과 수사상 적법성 판단 요소에 관한 연구

A Study on the Technical Characteristics of Port Scan-Based Open Source Intelligence (OSINT) Collection and the Factors for Assessing Investigative Legality

김영국* · 정두원**

* 서울경찰청 송파경찰서 수사과, 성균관대학교 과학수사학과 석사과정(주저자)

** 성균관대학교 과학수사학과 부교수(교신저자)

ABSTRACT

최근 **사이버범죄**는 인프라의 분산·은닉·가상화로 인해 전통적인 압수·수색 중심 수사만으로는 초기 대응에 한계가 있다. 이에 포트스캔 기반 공개출처정보는 공개 네트워크상에 노출된 포트와 서비스 구조를 파악하여 범죄 인프라를 식별하고 후속 수사의 방향을 설정하는 정보수집 수단으로 활용된다. 그러나 포트스캔이 단순한 공개 정보 확인인지, 아니면 정보통신망법상 침입 또는 위법한 정보수집에 해당하는지에 대해서는 명확한 판단 기준이 충분히 축적되어 있지 않다. 본 연구는 능동적 포트스캔과 외부 플랫폼 기반 수동적 검색의 기술적 특성을 구분하여 살펴본 뒤, 정보통신망법상 침입 개념, 형법상 정당행위, 형사소송법상 영장주의 등 관련 법원칙과 판례를 중심으로 수사상 적법성 판단 요소를 검토하였다. 그 결과 보호조치 우회 여부, 접근권한의 범위, 스캔 강도와 범위의 비례성, 정보 취득 단계의 차등성이 핵심 요소로 도출되었으며, 이는 수사 실무에서 허용 범위와 한계를 논의하는 참고 기준이 될 수 있음을 확인하였다.

KEYWORD

포트스캔, 공개출처정보(OSINT), 적법성, 사이버수사, 영장주의, 정보통신망 침입

I. 서론

오늘날 범죄는 물리적 공간을 넘어 디지털 환경으로 확장되면서, 그 양상 또한 조직화·지능화되고 있다.¹ 특히 VPN, Proxy, Tor 등과 같은 익명화 기술²의 확산으로 인해 수사기관은 범죄자에 비해 정보 접근에서 불리한 '정보 비대칭성'에 직면하고 있으며, 동시에 영장주의와 적법절차를 준수해야 한다는 제약으로 인해 신속한 대응에 한계를 가진다.³

이러한 한계를 보완하기 위한 수단으로 공개출처정보(Open Source Intelligence, OSINT)의 활용이 중요해지고 있다. OSINT는 합법적으로 접근 가능한 정보를 수집·분석하여 수사 단서를 도출하는 활동으로, 그중 포트스캔은 대상 시스템의 개방 포트와 서비스 구조를 확인함으로써 범죄 인프라를 신속히 파악할 수 있는 기술적 수단으로 활용된다.

그러나 포트스캔은 그 기술적 유용성에도 불구하고 법적·윤리적 쟁점을 내포한다. 수사 과정에서 수행되는 포트스캔이 경우에 따라 위법한 정보수집 또는 정보통신망 침입으로 평가될 가능성이 있으며, 그 결과로 확보된 정보의 증거능력 또한 문제될 수 있다. 특히 관련 판례와 명확한 가이드라인이 부족한 현실에서 수사관들은 법적 책임에 대한 우려로 소극적 수사에 머무르는 위축효과를 겪고 있다.⁴

이러한 문제의식에서 본 연구는 포트스캔을 단순한 OSINT 기법이 아니라 비침입적 탐지행위로 재구성하고, 기존 형사소송법상의 정보수집 유형으로는 충분히 설명되지 않는 독자적 법적 쟁점을 규명하는 데 목적이 있다. 포트스캔은 내부 데이터 접근 없이도 외부에서 시스템 상태 정보를 추출할 수 있으며, 단일 행위로는 침해성이 낮지만 대량·자동화될 경우 침해 효과가 확대될 수 있다는 점에서 기존 논의와 구별된다.

따라서 본 연구는 포트스캔의 적법성 판단을 위해 공개성, 침해성, 자동화 수준, 정보 결합 가능성 등을 중심으로 한 구조화된 기준을 제시하고, 이를 통해 임의수사와 강제처분의 경계 설정, 접근행위의 위법성 판단, 그리고 디지털 환경에서의 정보 인지 범위를 규범적으로 재정립하고자 한다.

1 이후기 외, 랜섬웨어 분석 및 탐지패턴 자동화 모델에 관한 연구, 한국정보통신학회논문지, 제21권 제8호, 한국정보통신학회, 2017, 1581-1588면.

2 임화섭, "구글, 사이버공격 악용 우려 中 기업 'IP아이디어'에 전쟁 선포", 연합뉴스, 2026. 1. 29. <https://www.yna.co.kr/view/AKR20260129150800009>, (검색 2026. 3. 3.).

3 김학신, 디지털 범죄 수사와 기본권에 관한 연구, 책임연구보고서 2009-04, 치안정책연구소, 2009, 3-4면.

4 하태인, 형사소송법 제308조의2(위법수집증거배제법칙)의 해석, 형사정책연구, 제25권 제4호, 한국형사법무정책연구원, 2014, 1-22면.

II. 사이버 수사에서 OSINT의 역할과 실무적 메커니즘

1. 사이버 수사에서 OSINT의 역할과 비중

오늘날 사이버 수사는 전통적인 형사·수사 방식과 달리 물리적 공간이 아닌 네트워크 공간을 주요 범죄 현장으로 삼는다.⁵ 전자적 환경에서 범죄의 실행과 결과는 유형의 물증이 아니라 시스템 로그, IP 주소, 접속 기록, 트래픽 데이터 등과 같은 디지털 흔적으로 남게 되며,⁶ 이러한 전자적 증거는 범죄의 행위자 특정과 행위 경로 추적에 있어 핵심적 역할을 수행한다.⁷ 특히 전자적 증거는 인터넷 서비스 제공자(ISP)의 가입자 정보와 결합될 경우 행위자 특성의 기초 자료로 기능⁸하며, 정확한 시간 정보와 함께 분석될 때 그 증거적 가치가 강화된다.

OSINT는 공개 출처로부터 합법적으로 수집 가능한 정보를 체계적으로 분석하여 수사적 의미를 도출하는 정보활동을 의미한다. 전통적으로 OSINT는 군사·정보기관 영역에서 발전하였으나, 최근에는 사이버 범죄 수사, 디지털 포렌식, 위협 인텔리전스 분야에서 핵심적 도구로 자리 잡았다.⁹

사이버 수사에서 OSINT는 단순 보조 수단이 아니라 초기 첩보 수집 단계에서부터 피의자 특정, 범죄 인프라 구조 분석, 공범 관계 추적, 범죄수익 흐름 분석에 이르기까지 전 과정에 관여하는 핵심 메커니즘으로 기능한다.

가. 범죄 인지 및 첩보 수집단계

사이버 범죄의 인지 및 초기 대응 단계는 전통적 형사절차에서의 신고 접수 후 현장 확인 중심 구조와 달리, 디지털 환경에서 발생하는 사건 특성상 조기 탐지와 예비 검토를 통해 사건 발생 여부를 신속히 확인하고, 그 심각도와 긴급성을 평가하는 과정이 선행된다.¹⁰

이러한 구조는 디지털 환경에서 단서가 분산되어 존재하고 신속히 변경·삭제될 수 있다는 특성과

5 강철하·강윤정, 디지털 포렌식에서 디지털증거의 특성과 법적 쟁점, 법학논총, 제19권 제3호, 조선대학교 법학연구원, 2012, 29면.

6 안성수, 디지털 증거의 증거능력, 법조, 제66권 제1호, 사단법인 법조협회, 2017, 5면.

7 탁희성, 형사절차상 digital evidence에 관한 연구, 형사정책연구원 연구총서 02-02, 한국형사법무정책연구원, 2002, 11-12면.

8 OSCE (Organization for Security and Co-operation in Europe), Guidelines on Cybercrime Investigation, Sep. 18, 2015, 27면.

9 김경한 외, OSINT기반의 활용 가능한 사이버 위협 인텔리전스 생성을 위한 위협 정보 수집 시스템, Review of KIISC, 제29권 제6호, 한국정보보호학회, 2019, 75-80면.

10 한국인터넷진흥원, 침해사고 조치 가이드, 2012, 5-6면.

결합될 때, 초기 단계에서의 체계적 정보 수집과 분석 활동의 중요성을 더욱 강조한다.¹¹ 특히 사이버 사건은 국외 인프라, 익명화 기술, 클라우드 기반 서비스 등을 경유하는 경우가 많아 즉각적인 행위자 특징이 곤란할 수 있으므로, 공개 정보 및 기술적 단서를 활용한 사전적 정황 파악과 정교한 선별 절차가 초기 대응 단계의 핵심 기능으로 작용한다.¹²

결국, 사이버 범죄의 인지 및 첩보 수집 단계는 단순한 신고 확인 절차를 넘어, 위험 기반 분류·우선순위화와 초기 분석이 결합된 구조적 대응 활동으로 이해할 수 있으며, 이는 이후 강제수사 또는 기술적 조치의 필요성과 범위를 판단하는 기초 자료를 형성한다.

이러한 양상은 수사현장에서 단순히 사건 발생 이후의 확인 절차뿐 아니라, 공개 채널과 다크웹 상에서 반복적으로 나타나는 범죄용 도구·서비스의 흐름과 구조를 이해하고 선제적으로 탐지할 필요를 강조한다. 즉, OSINT를 통해 다크웹 포럼 또는 서비스형 공격 플랫폼에서 유통되는 범죄 도구와 패턴을 체계적으로 모니터링함으로써, 잠재적 공격 징후나 범죄화 가능성이 높은 흐름을 초기에 포착하는 실무적 중요성이 존재한다.

나. 피의자 특정

사이버 수사에서 피의자 특정은 단순히 실명을 곧바로 확인하는 절차라기보다, 행위자·인프라·범죄연관성을 유기적으로 연결하여 합리적 의심을 구축하고, 이를 실효적인 수사 단서로 정제해 나가는 일련의 과정이다. 이때 OSINT는 사건 관련 공개 단서를 빠르게 확장하고, 도메인·IP·계정·핸들·지갑주소 등과 같은 디지털 식별자를 중심으로 관계망을 구성하며, 다수 출처의 교차검증을 통해 특정 가능성을 단계적으로 끌어올리는 핵심 기능을 수행한다.¹³ 특히 수사자원은 제한되어 있으므로, 사건을 선착순이 아니라 위험도·긴급도·행위자 특성 등 리스크 평가 요인에 따라 우선 순위화해야 한다는 점에서, 피의자 특정 단계의 OSINT는 분석을 넘어 사건화·배당·전환의 기준까지 좌우한다고 보아야 한다.

피의자 특정 단계는 단번에 “누가 행위자인가”를 확정하는 절차라기보다는, 복수의 행위자 후보군을 설정하고 공개된 단서를 통해 가설을 경쟁시키는 과정으로 이해할 수 있다. 특히 침해지표, 유출 공지, 범죄 포럼 게시물 등과 같은 공개 위협정보는 행위자의 동기, 대상, 수법을 추론하는 간접 단서로 기능한다. ENISA에 따르면 전체 침해 사건 중 상당 비율이 사이버범죄 포럼에서의 데이

11 노소형·지성우, 디지털 증거의 긴급한 보전을 위한 법제 개선 연구, 한국IT서비스학회지, 제19권 제3호, 한국IT서비스학회, 2020, 59-60면.

12 이경열·박제민, 역외 압수·수색 수사에 관한 한일 최고법원판례 비교연구, 비교형사법연구, 제24권 제3호, 한국비교형사법학회, 2022, 129면.

13 앤소니 운체 외, 사이버수사에서 귀속문제 의사결정을 위한 공개출처정보 처리 자동화, 디지털포렌식연구, 제15권 제2호, 한국디지털포렌식학회, 2021, 86-98면.

터 유출로 이어지고 있으며, 이는 포럼 기반 유출이 단순한 사후 결과에 그치지 않고 추적 및 분석의 단서로 활용될 수 있음을 시사한다.¹⁴ 이러한 통계는 포럼 기반 유출이 범죄 생태계의 구조적 일부임을 보여주며, 수사 실무에서는 이를 금전 동기형, 기회주의형 등과 같은 행위자 유형 분류 및 우선순위 판단의 보조 지표로 활용할 수 있다.

다. 범죄 인프라 분석

사이버 범죄는 단일 행위자의 고립된 침해행위라기보다, 다층적 네트워크 인프라와 분산된 디지털 자원을 기반으로 수행되는 구조적 활동의 성격을 갖는다. 이에 따라 현대 사이버수사에서 범죄 인프라 분석은 행위자 특정 이전 단계에서 필수적인 분석 절차로 자리 잡고 있으며, OSINT 도구는 이러한 인프라 구조를 가시화하는 핵심 수단으로 기능한다.

범죄 인프라 분석이란 공격자가 활용하는 서버, 도메인, IP 대역, 인증서, 호스팅 환경, 클라우드 서비스, 암호화 통신 채널 등 기술적 기반을 식별하고 그 상호 연계를 파악하는 과정을 의미한다. 인터넷 전반을 스캐닝하여 노출 자산을 관측하는 Censys와 같은 플랫폼은 인터넷 호스트 및 서비스의 전반적 지도를 제공함으로써, 공개적으로 노출된 서비스의 배너 정보, 포트 상태, 인증서 재사용 여부 등을 분석 가능하게 한다. 이러한 데이터는 특정 캠페인에 사용된 서버군의 공통점이나 재사용 인프라를 식별하는 데 활용될 수 있다.

OSINT 기반 인프라 분석은 도메인, IP 주소, 인증서, 서비스 배너 등과 같이 공개적으로 수집 가능한 기술적 단서를 확장·연계하여 공격자의 인프라 구조를 식별하는 방식으로 기능한다. 이러한 분석은 개별 침해 사건의 단편적 증거에 그치지 않고, 반복적으로 활용되는 전술·기법·절차 및 인프라 자산의 재사용 여부를 파악하는 단계로 발전할 수 있다.

라. 가상자산 및 다크웹 수사와의 연계

현대 사이버범죄는 다크웹 기반 시장과 가상자산을 매개로 한 거래 구조 속에서 조직화되는 양상을 보이고 있다. Europol의 IOCTA 2024 보고서는 다크웹이 여전히 사이버범죄 활동의 중요한 촉진 기반 환경으로 기능하고 있으며, 범죄 도구, 악성코드, 탈취 데이터, 접근 권한 등이 암시장 형태로 거래되고 있음을 지적한다.¹⁵ 특히 랜섬웨어와 같은 서비스형 범죄 모델은 기술적 진입 장벽을 낮추고 범죄자 간 역할 분화를 심화시키는 구조로 발전하고 있으며, 범죄 생태계 내에서 전문화된 분업 체계를 강화하는 경향을 보인다.¹⁶

14 박웅신, 다크웹상 범죄정보 자동 수집·분석 플랫폼 도입의 고려사항 연구, 형사정책, 제35권 제3호, 한국형사정책학회, 2023, 297-327면.

15 Europol, Internet Organised Crime Threat Assessment (IOCTA) 2024, Luxembourg: Publications Office of the European Union, Jul. 2024, 5-7면.

또한 보고서는 암호화폐가 범죄 수익의 이전 및 세탁 과정에서 핵심적 역할을 수행하고 있음을 분석하며, 다크웹 포럼과 온라인 커뮤니티가 범죄 서비스의 광고·모집·거래의 장으로 기능하고 있음을 설명한다. 이러한 분석은 다크웹과 가상자산이 단순한 부수적 요소가 아니라, 현대 사이버범죄 생태계의 구조적 기반으로 작동하고 있음을 시사한다.¹⁷

2. 포트스캔의 기술적 특성과 수사활용 유형

가. 능동적 포트스캔

능동적 포트스캔은 대상 시스템에 직접 네트워크 패킷을 전송하고, 그 응답 또는 무응답을 바탕으로 개방 포트, 서비스 존재 여부, 필터링 상태 등을 추정하는 방식이다.¹⁸ 수사 실무에서는 범죄 인프라가 실제로 외부와 어떤 방식으로 통신하고 있는지 확인하고, 후속 분석이나 압수·수색의 필요성을 판단하는 기초 자료를 확보하는 데 활용될 수 있다. 다만 대상 시스템과 직접 상호작용한다는 점에서 수동적 검색보다 탐지 가능성과 법적 논란의 여지가 크다.

능동적 포트스캔은 사용되는 패킷 구조와 연결 성립 여부에 따라 TCP SYN, TCP Connect, UDP, FIN/NULL/Xmas 스캔 등으로 구분된다. 각 기법은 정보 획득 방식과 정확도, 탐지 가능성, 로그 흔적의 정도에서 차이를 보이며, 이러한 차이는 단순한 기술적 차이를 넘어 수사상 허용 범위와 비례성 판단에도 영향을 미친다. 따라서 포트스캔의 적법성은 단순히 스캔 여부만으로 판단할 것이 아니라, 어떠한 방식으로 어느 범위까지 수행되었는지를 함께 검토할 필요가 있다.

(1) TCP SYN 스캔

TCP SYN 스캔은 TCP의 연결 절차를 끝까지 완료하지 않고 초기 응답만 확인하여 포트 개방 여부를 파악하는 방식이다. 대상 포트가 열려 있으면 일반적으로 SYN/ACK 응답이 반환되고, 닫혀 있으면 RST 응답이 나타나므로, 이를 통해 연결을 완성하지 않은 상태에서도 포트 상태를 추정할 수 있다.¹⁹

이 기법은 전체 연결을 수립하는 방식보다 상대적으로 은밀하고 로그 흔적이 적을 수 있어 경찰과 보안 점검에 널리 활용된다. 반면 직접 패킷을 전송한다는 점에서 외부의 단순 열람과는 구별되

16 이호석 외, 2024.1Q KARA 랜섬웨어 동향 보고서, SK윌더스, 2024, 4-5면, 16-17면.

17 Europol, Internet Organised Crime Threat Assessment (IOCTA) 2024, 13-17면, 52-55면.

18 조상덕, 보안취약점 진단을 활용한 보안관제 고도화에 관한 연구, 건국대학교 정보통신대학원 석사학위논문, 2014, 58면.

19 한국정보보호진흥원, 네트워크 취약점 점검도구 선정 지침, 2002, 221면.

며, 수사상으로는 정보 취득 수준이 제한적인지, 보호조치 우회가 수반되었는지 여부가 적법성 판단의 핵심이 된다.

(2) TCP Connect 스캔

TCP Connect 스캔은 TCP의 3단계 연결 절차를 완전히 수행하여 대상 포트의 개방 여부를 확인하는 방식이다. 운영체제의 표준 소켓 기능을 이용해 실제 연결 성공 여부를 확인한다는 점에서 구조가 가장 직관적이고 결과 해석도 비교적 명확하다.²⁰

다만 이 방식은 연결이 실제로 성립되므로 대상 시스템에 접속 기록이 남을 가능성이 높고 탐지 가능성도 상대적으로 크다.

그러나 이러한 기술적 특성이 곧바로 법적 침해성의 정도를 결정하는 것은 아니다. 포트스캔의 적법성은 연결의 완성 여부가 아니라, 해당 행위가 정보주체의 합리적 프라이버시 기대를 침해하는지, 취득되는 정보의 내용과 민감성, 그리고 법률유보 및 비례성 원칙에 부합하는지 등을 기준으로 판단되어야 한다.

따라서 TCP Connect 스캔이 SYN 스캔보다 항상 더 침해적이라고 단정할 수 없으며, 공개된 서비스 포트에 대한 제한적 확인에 그치는 경우에는 침해성이 낮게 평가될 가능성도 있다. 결국 포트스캔 기법 간 기술적 차이는 위험도나 탐지 가능성에 관한 참고 요소에 불과하며, 법적 평가는 개별 사안의 구체적 맥락에 따라 규범적으로 이루어져야 한다.

(3) UDP 스캔

UDP 스캔은 비연결형 프로토콜인 UDP의 특성을 이용하여 특정 포트에 패킷을 전송한 뒤, ICMP 오류 메시지나 응답 부재를 바탕으로 포트 상태를 추정하는 방식이다.²¹ 일반적으로 폐쇄된 포트에서는 오류 메시지가 반환되고, 개방된 포트는 별도 응답이 없을 수도 있어 결과 해석이 TCP 방식보다 복잡하다.

이 때문에 UDP 스캔은 방화벽, 속도 제한, 오류 메시지 차단 등의 영향을 크게 받아 정확도가 떨어질 수 있고, 시간도 더 오래 걸릴 수 있다. 그럼에도 DNS, NTP 등 UDP 기반 서비스 확인에는 필요성이 있으므로, 수사 실무에서는 목적이 명확한 최소 범위의 점검으로 제한하는 것이 바람직하다.

20 한국정보보호진흥원, 네트워크 취약점 점검도구 선정 지침, 218~219면.

21 한국정보보호진흥원, 네트워크 취약점 점검도구 선정 지침 162면.

(4) TCP FIN·NULL·Xmas 스캔

TCP FIN·NULL·Xmas 스캔은 비정상적이거나 예외적인 TCP 플래그 조합에 대한 응답 차이를 이용해 포트 상태를 간접적으로 판별하는 방식이다. 정상적인 연결 절차를 따르지 않기 때문에 일부 환경에서는 SYN 기반 스캔보다 탐지 가능성이 낮게 나타날 수 있다.²²

다만 이러한 기법은 TCP 표준과 운영체제 구현에 크게 의존하여 결과 해석의 일관성이 낮고, 최신 보안장비에서는 오히려 이상행위로 탐지될 가능성도 존재한다.

무엇보다 이들 스캔은 정상적인 연결 요청 패턴을 벗어난 패킷을 통해 응답을 유도한다는 점에서, 단순한 상태 확인을 넘어 접근 통제 메커니즘의 한계를 탐지하는 성격을 가진다. 특히 방화벽 등으로 설정된 접근 제한은 관리자의 명시적 통제 의사를 반영한 것으로 볼 수 있으므로, 이를 전제로 한 비정상적 패킷 전송은 형식적 인증 절차를 거치지 않더라도 해당 의사를 잠탈하는 행위로 평가될 여지가 있다.

따라서 TCP FIN·NULL·Xmas 스캔은 단순한 정보 확인을 넘어 ‘우회적 접근 시도’로 해석될 가능성이 있으며, 경우에 따라 형법상 관리자의 의사에 반하는 접근과 연결될 수 있다. 결국 이러한 기법은 수사상 활용 가능성에도 불구하고, 일반적인 포트 확인보다 법적 침해성이 문제될 여지가 크므로 보다 신중한 평가가 요구된다.

나. 수동적 포트스캔 데이터베이스 활용: 외부 플랫폼 기반 검색

수동적 포트스캔은 대상 시스템에 직접 패킷을 전송하지 않고, 제3의 플랫폼이 사전에 수집한 인터넷 노출 정보를 조회하여 포트, 서비스, 배너, 인증서, 위치, 취약점 노출 여부 등을 확인하는 방식이다. 이는 대상 시스템과 직접 상호작용하지 않으므로 탐지 위험과 서비스 장애 가능성이 낮고, 수사 초기 단계에서 범죄 인프라를 신속히 파악하는 데 활용될 수 있다.

Shodan, Censys, Criminal IP와 같은 플랫폼은 인터넷 전역에 대한 스캔 결과를 데이터베이스화하여 검색 기능을 제공한다는 공통점을 가진다. Shodan은 인터넷에 노출된 장비와 서비스의 배너 정보를 수집·색인하여 검색할 수 있도록 하는 대표적인 스캐닝 기반 플랫폼이다.²³ Censys는 인터넷 전역의 호스트, 서비스, 인증서 정보를 구조화하여 제공하는 인터넷 측정 기반 플랫폼이다.²⁴ Criminal IP는 스캔 데이터에 위협 인텔리전스 정보를 결합하여 취약점 노출 및 악성 인프라 분석을 지원하는 플랫폼이다.²⁵

22 한국정보보호진흥원, 네트워크 취약점 점검도구 선정 지침, 225-226면.

23 Matherly, J., "Complete Guide to Shodan," Shodan LLC, 2018.

24 Censys, Censys documentation, 2026. <https://docs.censys.com/>, (검색 2026. 3. 3.).

25 Criminal IP, "Criminal IP: Cybersecurity search engine," 2026. <https://CriminalIP.io>, (검색 2026. 3. 3.).

그러나 수동적 포트스캔은 수사기관이 직접 대상 시스템에 접근하는 것이 아니라 제3자가 수집·보유한 데이터를 조회한다는 점에서, 능동적 포트스캔과 법적 성격이 근본적으로 구별된다. 이는 통신자료 제공 요청이나 금융정보 조회와 유사한 ‘제3자 보유 정보에 대한 접근’ 구조를 가지며, 단순한 현장 관찰로 평가하기 어렵다.

따라서 그 적법성은 단순히 공개정보 여부만으로 판단될 수 없고, 정보의 공개성, 회원가입·유료 여부 등과 같은 접근 방식의 제한성, 개인정보 해당성 및 정보 결합 가능성을 중심으로 종합적으로 검토되어야 한다. 특히 정보가 식별 가능한 형태로 활용되거나 체계적으로 수집·분석되는 경우에는 개인정보 보호법 적용 및 별도의 법적 근거가 문제 될 수 있다.

결국 수동적 포트스캔은 제3자 보유 정보 접근이라는 법적 구조를 전제로, 형사소송법상 임의수사의 범위 내 행위인지 여부를 개별 사안에 따라 판단해야 한다.

다. 소결

결국 포트스캔 기법 간 기술적 차이는 단순한 설명 요소에 그치지 않고, 일정한 법적 평가 구조 속에서 해석될 필요가 있다. 이에 본 연구는 포트스캔의 적법성 판단을 위한 3단계 기준을 제시한다.

첫째, 권리침해성 판단 단계에서는 해당 스캔이 정보주체의 합리적 프라이버시 기대를 침해하는지 여부를 평가한다. 이때 접근 대상의 공개성, 인증 요구 여부, 취득 정보의 내용과 민감성이 주요 기준이 되며, 공개된 포트에 대한 단순 상태 확인은 일반적으로 침해성이 낮은 행위로 평가될 수 있다.

둘째, 수사 필요성 및 상당성 판단 단계에서는 해당 스캔이 범죄 혐의와 관련되고 수사 목적 달성을 위해 필요한 범위 내에 있는지를 검토한다. 스캔의 범위, 반복성, 대체 수단의 존재 등이 주요 고려 요소가 되며, 무차별적 스캐닝은 원칙적으로 제한될 필요가 있다.

셋째, 법적 정당화 가능성 판단 단계에서는 해당 행위가 임의수사로 허용되는지 또는 영장이 요구되는 강제처분에 해당하는지를 판단한다. 이 과정에서는 형사소송법상 압수·수색 법리와 위법수집 증거 배제 원칙 등이 종합적으로 고려된다.

이와 같은 구조에서 권리침해성은 선행적 기준으로 기능하여, 침해성이 일정 수준 이상인 경우 강제처분 여부 판단으로 연결되며, 침해성이 낮은 경우에는 수사 필요성과 상당성이 중심 기준으로 작용한다. 또한 요소 간 충돌이 발생하는 경우에는 기본권 보호 원칙에 따라 침해성 요소에 우선적 가중치를 부여하는 것이 타당하다.

Ⅲ. 주요국 수사기관의 OSINT 활용 현황 및 지침 비교

1. 미국의 사례

가. FBI²⁶ 및 법무부²⁷의 OSINT 수행 가이드라인

미국에서 OSINT의 수집·활용은 수사 단계에 따라 허용 범위와 통제 수준이 달라지는 구조로 설계되어 있다. 특히 미국 법무부의 장관지침은 평가 단계에서 공개적으로 이용 가능한 정보 확보, 정부기록 조회, 온라인 서비스 및 상업적 데이터 활용 등 비교적 침해성이 낮은 방법 중심의 정보 수집을 허용한다.

한편 PCLOB는 공개출처 정보가 낮은 수준의 침해 수단이 될 수 있음을 인정하면서도, 대규모 집적·결합을 통해 개인의 민감한 정보가 재구성될 경우 프라이버시 및 시민자유 침해 위험이 증가할 수 있음을 지적한다.

이러한 점에서 미국의 OSINT 규율은 두 가지 축으로 이해될 수 있다. 즉, FBI 지침은 수사 단계에 따른 권한 범위를 설정하는 ‘단계적 정당화 모델’을 중심으로 하고, 법무부 및 감독기구의 기준은 승인, 기록, 보관·폐기, 공유 제한 등 운영 전반에 대한 통제를 강조하는 ‘거버넌스 모델’을 형성한다.

결국 미국의 OSINT 체계는 권한 부여와 운영 통제를 분리하여 구성하고 있으며, 이는 공개정보 활용의 적법성을 확보함과 동시에 집적·추론 위험을 구조적으로 관리하려는 이중적 규율 구조로 평가할 수 있다.

나. 공개된 정보에 대한 수사권 행사 범위와 판례

미국 수사와 정보활동에서 공개된 정보(Publicly Available Information, 이하 PAI)는 영장이나 강제처분 없이 합법적으로 접근 가능한 정보 범주를 의미하며, 그 판단 기준은 정보의 내용이 아니라 공개성과 접근 가능성에 있다. 미국 법무부 장관지침은 공개적으로 출판·방송된 정보, 온라인 접근 정보, 공중의 요청에 따라 제공되는 정보뿐 아니라 구독이나 구매를 통해 합법적으로 취득 가능한 정보까지 포함하여 PAI를 정의하고 있으며, FBI 또한 동일한 공개성 기준을 채택하고 있다.

26 Privacy and Civil Liberties Oversight Board, Use of Open Source Information by the Federal Bureau of Investigation, Staff Report, Washington, DC, USA, Nov. 20, 2025.

27 U.S. Department of Justice, Office of Justice Programs, Bureau of Justice Assistance, Real-Time and Open Source Analysis (ROSA) Resource Guide. Washington, DC, USA: BJA, 2017.

한편 PCLOB는 공개정보가 일반적으로 낮은 침해성을 가지는 수단이 될 수 있음을 인정하면서도, 대량 수집·자동화 분석 및 데이터 결합을 통해 개인의 민감한 정보가 재구성될 경우 프라이버시 및 시민자유 침해 위험이 증가할 수 있음을 지적한다.

이러한 PAI 개념은 국내 형사소송법 해석에 있어, 공개적으로 접근 가능한 정보에 대한 수집은 원칙적으로 임의수사로 평가될 수 있다는 기준을 제공한다. 다만 공개정보라 하더라도 대규모 집적과 결합을 통해 침해성이 실질적으로 증가하는 경우에는, 단순 정보수집을 넘어 강제처분에 준하는 효과가 발생할 수 있어 영장주의 적용 가능성이 문제된다.

한편 PCLOB는 FBI의 오픈소스 정보 활용을 설명하면서, 오픈소스 정보가 상업적으로 판매되는 정보와 대중이 무료로 접근 가능한 정보를 모두 포함한다고 구분한다. PCLOB는 이러한 공개정보가 일반적으로 가장 덜 침해적인 수단이 될 수 있음을 인정하면서도, 대량 수집과 데이터 결합을 통해 개인의 민감한 정보가 재구성될 경우 프라이버시 및 시민자유 침해 위험이 발생할 수 있음을 지적한다.

따라서 미국의 PAI 개념은 OSINT의 적법성을 직접 정당화하는 근거라기보다, ‘공개성에 따른 임의수사 가능성’과 ‘집적에 따른 침해성 증가 시 영장 필요성’이라는 이중적 판단 구조를 도출하는 비교법적 기준으로 이해될 필요가 있다.

2. 유럽 및 국제기구의 사례

가. 유로폴(Europol)의 OSINT 프레임워크²⁸와 개인정보보호규정²⁹

Europol은 유럽연합 차원의 수사기관 협력 허브로서 OSINT 자료를 수사와 정보 분석에 활용하는 한편, GDPR에 기반한 엄격한 데이터 보호 체계와 결합된 운영 구조를 갖추고 있다. Europol은 OSINT를 포함한 모든 데이터 처리 과정에 대해 별도의 감독 기능을 두어, 수집·분석·공유 전 단계에서 법적 근거, 목적 제한, 정보주체 권리 보장을 지속적으로 점검한다. 또한 공개된 정보라 하더라도 개인을 식별할 수 있는 경우 GDPR을 적용하며, 데이터 최소화와 비례성 원칙을 핵심 기준으로 삼고 있다.

이러한 원칙은 개인정보 보호법과 비교될 수 있다. 국내법 역시 목적 제한, 최소 수집, 보유기간

28 Europol, OSINT Monitoring, Public Document, The Hague, NL, 14 Feb. 2025; updated 24 Mar. 2025.

29 Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation), Official Journal of the European Union, L 119, 4 May 2016.

제한 및 정보주체 권리 보장을 규정하고 있어 GDPR과 기능적으로 유사한 구조를 가진다.

다만 GDPR이 비례성 원칙을 중심으로 정보처리 전반에 걸쳐 침해 최소화성과 필요성을 명시적으로 요구하는 반면, 국내법은 이러한 기준이 개별 조항을 통해 분산적으로 구현되는 경향이 있다. 또한 Europol과 같이 OSINT 처리 전반을 통합적으로 감독하는 제도적 장치가 국내에는 충분히 정립되어 있지 않다는 점에서 구조적 차이가 존재한다.

따라서 Europol의 OSINT 운영모델은 공개정보 활용과 개인정보 보호 간 균형을 제도적으로 구현한 사례로 평가되며, 국내에서도 OSINT 활용 기준을 명확히 하고 비례성 및 최소침해 원칙을 보다 체계적으로 정립할 필요가 있음을 시사한다.

나. 인터폴³⁰ 및 부다페스트 협약³¹에 따른 국제 공조 체계

OSINT은 초국경적 사이버범죄 대응에서 국가 간 정보 격차를 보완하는 수단으로 기능하며, 국제 공조 체계와 결합될 때 그 실효성이 강화된다. 특히 인터폴과 부다페스트 협약은 OSINT 기반 정보수집·분석 결과의 국제적 공유를 가능하게 하는 제도적 틀을 제공한다. 인터폴 헌장은 정보 교환과 상호 지원³²을 핵심 임무로 규정하면서도 정치적·군사적·종교적 사안에 대한 개입을 금지하고 있어, OSINT 활용 역시 형사 범죄 수사 목적 범위 내에서 정당화된다.³³

부다페스트 협약은 전자적 증거 확보와 국제 공조 절차를 규정한 최초의 국제조약으로, 저장 데이터 보존 및 공개정보 확보 절차를 통해 디지털 증거의 국제적 연계를 제도화한다. 대한민국은 2020년 협약을 비준한 당사국으로서 그 규범은 국내법 질서 내에서 일정한 법적 의미를 갖는다.

특히 협약 제32조는 공개적으로 접근 가능한 데이터에 대해서는 별도의 강제 절차 없이 접근할 수 있음을 규정하고 있어, OSINT 활동의 국제적 정당성을 뒷받침하는 근거로 해석될 수 있다. 그러나 이러한 규정이 곧바로 국내 수사기관의 독자적 법적 근거로 기능하는 것은 아니며, 그 적용은 헌법 제6조에 따라 국내법과의 관계 속에서 해석되어야 한다.

따라서 공개정보에 대한 접근이라 하더라도 그 행위가 실질적으로 법익을 침해하거나 강제처분에 준하는 효과를 가지는 경우에는 「형사소송법」상 영장주의가 적용될 수 있다. 결국 부다페스트

30 International Criminal Police Organization – INTERPOL, INTERPOL Africa Cyberthreat Assessment Report 2025, Lyon, France: INTERPOL, 2025.

31 Convention on Cybercrime (Budapest Convention), Council of Europe European Treaty Series – No. 185, Budapest, Hungary, 23 Nov. 2001.

32 INTERPOL, “Constitution of the International Criminal Police Organization–INTERPOL,” Art. 2, 1956.

33 INTERPOL, “Constitution of the International Criminal Police Organization–INTERPOL,” Art. 3 1956.

협약 제32조는 OSINT의 국제적 정당성을 보완하는 규범으로 기능하되, 국내 수사에서의 적법성 판단은 여전히 국내법 체계에 따라 독자적으로 이루어져야 한다.

3. 한국 경찰의 현황 및 실무적한계

가. 경찰청 사이버 수사 운영 지침상의 OSINT 위치

한국 경찰은 디지털 전환에 따라 사이버범죄 대응 역량을 강화해 왔으며, 이 과정에서 OSINT 활용도 점차 확대되고 있다. 경찰청은 「범죄수사규칙³⁴」 등을 통해 정보수집·분석·공유 절차를 체계화하고 있으나, OSINT는 독립된 수사기법으로 명확히 규정되기보다는 정보수집의 한 유형으로 포괄적으로 다루어지고 있다.

이로 인해 공개정보 수집과 강제처분 간 경계 설정이 실무자의 판단에 의존하는 구조가 형성되어 있으며, 적법성 판단 기준의 구체성이 부족하다는 한계가 지적된다. 특히 공개정보라 하더라도 개인정보가 포함될 경우 「개인정보 보호법」의 적용 대상이 될 수 있고, 과도한 수집이나 이용은 위법성 논란으로 이어질 수 있다.³⁵

또한 디지털 증거 관리와 관련하여 무결성 및 절차적 기록 확보 원칙은 확립되어 있으나, OSINT와 같은 공개정보의 출처 검증 및 증거화 절차에 대한 구체적 기준은 상대적으로 미비한 상황이다.

결국 OSINT는 수사 초기 단계에서 중요한 역할을 수행하고 있음에도 불구하고, 법적 근거의 명확성, 개인정보 보호 기준과의 정합성, 그리고 증거화 절차의 구체화 측면에서 제도적 보완이 요구된다. 이에 따라 디지털 환경의 특수성을 반영한 명확한 운용 기준과 세부 지침의 마련이 필요하다.

나. 수사 현장에서의 포트스캔 활용 실태와 제약 사항

한국 경찰은 사이버범죄 수사의 초기 단계에서 범죄 인프라를 신속히 파악하기 위한 수단으로 포트스캔을 제한적으로 활용하고 있다.³⁶ 공개 서버의 서비스 노출 여부, 취약 포트 개방 상태, 악성 인프라 구조 등을 확인하는 과정에서 포트 정보 분석이 활용되며,³⁷ 이는 랜섬웨어 유포지, 피싱

34 경찰청, 범죄수사규칙, 경찰청훈령 제1194호, 2026.

35 김학경, 경찰의 온라인 공개개인정보 활용에 관한 법적 검토, 형사정책연구, 제35권 제1호, 한국형사법무정책연구원, 2024, 108-110면.

36 박현민 외, 보이스피싱 심박스 분석 및 수사활용 방안에 관한 연구, 디지털포렌식연구, 제16권 제3호, 한국디지털포렌식학회, 2022, 77-87면.

37 유인재 외, IP 포트 스캐닝을 이용한 불법 유통 플랫폼 추적 방법, 소프트웨어포렌식 논문지, 제19권 제4호, 한국소프트웨어감정평가학회, 2023, 115-122면.

서버, 불법 사이트 등의 위치 특정과 추가 피해 방지에 중요한 단서를 제공한다.

실무에서는 주로 공개 IP 대역에 대한 비침투적 스캔이나 피해 신고가 접수된 대상에 대한 확인 차원의 스캔이 이루어지며,³⁸ TCP SYN 스캔과 같은 경량화된 방식이 활용된다. 반면 무차별적 대규모 스캐닝은 법적 분쟁 가능성과 시스템 부하 등을 고려하여 지양되는 경향이 있다.

법적으로 포트스캔의 성격은 명확히 정립되어 있지 않으나, 통상 외부에서 접근 가능한 정보의 확인이라는 점에서 임의수사로 해석되는 경우가 많다. 다만 스캔의 범위와 강도가 과도한 경우에는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」상 침해행위로 평가될 가능성이 있어 신중한 운용이 요구된다. 이러한 불확실성은 수사관이 기술적 필요성과 위법성 사이에서 자율적으로 판단해야 하는 한계를 초래한다.

결국 포트스캔은 수사 실무에서 유용한 도구로 기능하고 있으나, 명확한 법적 기준과 통일된 운용 지침이 부족한 상황이다. 따라서 향후에는 적법성 판단 기준과 기술적 한계를 반영한 표준운영 절차를 마련하고, 교육 및 감독 체계를 강화할 필요가 있다.

IV. 포트스캔 기반 수사의 적법성 판단 기준

1. 정보통신망법상 침입행위와 수사권의 충돌

가. 포트스캔의 정당행위 해당 여부

포트스캔 기반 수사의 적법성은 해당 행위가 위법성 조각사유에 해당하는지 여부, 특히 「형법」 제20조의 정당행위로 평가될 수 있는지에 따라 판단된다. 형법 제20조는 “법령에 의한 행위 또는 업무로 인한 행위 기타 사회상규에 위배되지 아니하는 행위는 벌하지 아니한다”고 규정하고 있으며, 이에 따라 수사기관의 직무집행이 사회상규에 부합하는 범위 내에서 이루어진 경우 위법성이 조각될 수 있다. 문제는 포트스캔이 정보통신망에 대한 접근 신호를 전송하는 기술적 행위라는 점에서 일정한 침해성을 수반할 가능성이 있다는 점이다.

기술적으로 포트스캔은 특정 IP 주소의 개방 포트를 확인하기 위해 TCP SYN 패킷 등을 송신하는 절차로 구성되며, 이는 연결을 완전히 성립시키지 않더라도 대상 시스템에 네트워크 요청을 발생시킨다. 이러한 행위가 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」상 ‘침입’에 해당하는지 여부가 쟁점이 된다. 동 법은 정당한 접근권한 없이 정보통신망에 침입하는 행위를 금지하고 있으나³⁹, 외부에 공개된 서비스 포트에 대한 단순 접속 시도가 곧바로 보호법익 침해로 평가되는지

38 김진환 외, 불법 사이트 사건 사례를 통한 데이터베이스 증거물 획득 방안, 디지털포렌식연구, 제4권 제2호, 한국디지털포렌식학회, 2010, 42면.

에 대해서는 학설상 논란이 존재한다.⁴⁰

대법원은 일반적으로 수사기관의 직무집행이 사회통념상 허용될 상당성을 갖춘 경우 위법성이 조각될 수 있음을 판시한 바 있다.⁴¹ 이를 포트스캔에 적용하면, 공개된 서버의 서비스 노출 여부를 확인하는 수준의 기술적 탐색은 사회상규에 위배되지 않는 범위로 해석될 여지가 있다. 그러나 스캔 강도가 과도하거나 서비스 거부 상태를 초래할 정도의 부하를 유발하는 경우에는 비례성 원칙을 벗어나 정당행위로 인정되기 어렵다.

결국 포트스캔의 정당행위 인정 여부는 목적의 공익성, 범위의 특정성, 침해 최소화, 그리고 절차적 통제 존재 여부를 종합적으로 고려하여 판단되어야 한다. 이는 기술적 행위 자체의 중립성과 법적 평가의 규범성을 구별하여 접근해야 함을 의미하며, 향후에는 스캔 강도·대상·기록 보존 기준 등을 명문화한 세부 가이드 라인이 마련될 필요가 있다.

나. 부정한 접근권한에 대한 대법원 판례의 수사적 해석

포트스캔 기반 수사의 적법성 판단에서 핵심 쟁점은 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」상 ‘정당한 접근권한 없이 정보통신망에 침입한 행위’의 해석이다. 여기서 접근권한의 범위와 침입의 의미는 포트스캔 행위의 위법성 판단과 직접적으로 연결된다.

대법원은 정보통신망 침입죄의 성립 여부를 판단함에 있어, 기술적 보호조치의 우회 여부와 허용된 접근 범위의 초과 여부를 핵심 기준으로 제시하고 있다. 예컨대 대법원 2022도3413 판결은 비밀번호 등 보호조치를 우회한 경우 침입에 해당한다고 보았고,⁴² 대법원 2005도870 판결은 접근권한이 제한된 영역에 대해 허용 범위를 초과한 경우에도 침입죄 성립 가능성을 인정하였다.⁴³

이러한 판례 기준에 비추어 보면, 포트스캔이 곧바로 ‘부정한 접근’에 해당한다고 단정하기는 어렵다. 포트스캔은 일반적으로 외부에 개방된 포트의 연결 가능성 확인에 그치며, 보호조치 우회나 인증 절차 무력화를 수반하지 않는 경우가 많기 때문이다. 따라서 이러한 제한적 행위는 판례가 전제하는 침입의 전형적 유형과 구별될 여지가 있다.

다만 보호조치를 우회하거나 접근 범위를 실질적으로 초과하는 방식으로 수행되는 경우에는 침입행위로 평가될 가능성이 있다. 결국 포트스캔의 적법성은 기술적 행위의 성격과 보호조치 침해

39 정보통신망법 제45조(정보통신망의 안정성 확보 등) 제3항의 제1호

40 조성훈, 주거침입과 정보통신망침입: 보호법익과 ‘침입’의 해석론을 중심으로, 선진상사법률연구, 제80호, 법무부, 2017, 344-345면.

41 대법원 2005. 4. 15. 선고 2004도5372 판결.

42 대법원 2022. 7. 14. 선고 2022도3413 판결.

43 대법원 2005. 4. 29. 선고 2005도870 판결.

여부를 중심으로 개별적으로 판단되어야 한다.

2. 영장주의 원칙과 임의수사의 한계

가. 포트스캔을 압수·수색으로 볼 것인가? 현장관찰로 볼 것인가?

포트스캔 기반 수사의 적법성 판단에서 핵심 쟁점은 해당 행위를 「형사소송법」상 압수·수색에 준하는 강제처분으로 볼 것인지, 아니면 영장 없이 가능한 임의수사 또는 현장관찰로 평가할 것인지에 있다. 「형사소송법」 제215조에 따른 영장주의는 사생활의 비밀과 통신의 자유를 실질적으로 제한하는 경우 원칙적으로 영장을 요구한다.

압수·수색은 일반적으로 정보에 대한 실질적 지배 또는 강제적 확보를 의미하며, 대법원은 전자 정보에 대해서도 저장매체 접근·복제 행위를 이에 포함된다고 본다.⁴⁴ 이에 비해 포트스캔은 대상 시스템 내부 정보를 복제하거나 지배하지 않고 외부에서 응답 여부를 확인하는 행위라는 점에서 전통적 압수·수색과는 구별될 여지가 있다.

한편 포트스캔을 현장관찰에 비유하는 견해도 있으나, 물리적 공간에서의 수동적 관찰과 달리 포트스캔은 패킷 송신을 통해 대상 시스템의 반응을 유도하는 능동적 행위라는 점에서 동일하게 평가하기는 어렵다. 특히 TCP SYN 스캔과 같이 침해성이 제한된 경우라도, 시스템에 일정한 기술적 작용을 발생시킨다는 점에서 순수한 외부 관찰과는 구별된다.⁴⁵

결국 포트스캔의 법적 성격은 일률적으로 결정될 수 없고, 행위의 구체적 방식과 범위에 따라 임의수사와 강제처분 사이에서 규범적으로 판단되어야 한다.

나. 플레인 뷰 원칙의 디지털 공간 적용 가능성

포트스캔 기반 수사의 적법성 판단과 관련하여 플레인 뷰(Plain View) 원칙의 디지털 공간 적용 가능성은 영장주의의 예외 범위를 어디까지 확장할 수 있는지와 밀접하게 연결된다. 플레인 뷰 원칙은 적법한 장소에 있는 수사기관이 우연히 범죄 관련 증거를 인지한 경우, 별도의 영장 없이 이를 압수할 수 있도록 허용하는 이론으로 발전해 왔다.⁴⁶

포트스캔 기반 수사의 적법성 판단에서 핵심 쟁점은 해당 행위를 「형사소송법」상 압수·수색에 준하는 강제처분으로 볼 것인지, 아니면 영장 없이 가능한 임의수사 또는 현장관찰로 평가할 것인지에 있다. 「형사소송법」 제215조에 따른 영장주의는 사생활의 비밀과 통신의 자유를 실질적으로 제

44 대법원 2011. 5. 26. 선고 2009도1190 판결.

45 대법원 2023. 4. 27. 선고 2018도8161 판결.

46 U.S. Supreme Court, Coolidge v. New Hampshire, 403 U.S. 1971, 464-473면.

한하는 경우 원칙적으로 영장을 요구한다.

압수·수색은 일반적으로 정보에 대한 실질적 지배 또는 강제적 확보를 의미하며, 대법원은 전자정보에 대해서도 저장매체 접근·복제 행위를 이에 포함된다고 본다. 이에 비해 포트스캔은 대상 시스템 내부 정보를 복제하거나 지배하지 않고 외부에서 응답 여부를 확인하는 행위라는 점에서 전통적 압수·수색과는 구별될 여지가 있다. 미국 연방대법원은 Riley v. California 판결에서 디지털 정보의 특수성을 강조하며 전통적 수색 법리를 그대로 적용하는 것에 신중해야 한다고 판시하였다.⁴⁷

한편 포트스캔을 현장관찰에 비유하는 견해도 있으나, 물리적 공간에서의 수동적 관찰과 달리 포트스캔은 패킷 송신을 통해 대상 시스템의 반응을 유도하는 능동적 행위라는 점에서 동일하게 평가하기는 어렵다. 특히 TCP SYN 스캔과 같이 침해성이 제한된 경우라도, 시스템에 일정한 기술적 작용을 발생시킨다는 점에서 순수한 외부 관찰과는 구별된다.

따라서 포트스캔은 단순 관찰이 아닌 ‘제한된 범위의 능동적 탐색 행위’로 이해하는 것이 타당하다. 이에 따라 임의수사로 허용되기 위해서는 정보의 공개성, 행위의 비침투성(저침해성), 정보 취득 범위의 제한성이 충족되어야 하며, 이러한 요건을 벗어나는 경우에는 영장에 의한 통제가 요구된다.⁴⁸

결국 포트스캔의 법적 성격은 일률적으로 결정될 수 없고, 행위의 구체적 방식과 범위에 따라 임의수사와 강제처분 사이에서 규범적으로 판단되어야 한다.

3. 위법수집증거 배제원칙과 증거능력 확보 문제

가. 무분별한 스캔을 통해 확보된 IP 및 서비스 정보의 증거 가치

포트스캔 기반 수사의 적법성은 단순한 위법성 판단을 넘어, 그 결과로 확보된 정보가 형사재판에서 증거능력을 인정받을 수 있는지의 문제와 직결된다. 우리 형사소송법은 위법수집증거 배제원칙을 인정하고 있으며, 형사소송법 제308조의2에 따라 적법한 절차에 따르지 아니하고 수집한 증거는 원칙적으로 증거능력이 부정된다.

대법원은 위법수집증거의 배제 여부를 판단함에 있어 위법의 중대성, 고의성, 침해된 법익의 성격 등을 종합적으로 고려하여야 한다고 판시하고 있으며,⁴⁹ 이는 포트스캔을 통해 수집된 정보 역시 그 수집 과정의 적법성을 개별적으로 검토해야 함을 의미한다.

47 Riley v. California, 573 U.S. 373 (2014).

48 이관희, 디지털 저장매체에서 Plain View 원칙을 적용하기 위한 조건 - 미 연방판례를 중심으로 -, 범죄수사학연구, 제6권 제2호, 경찰대학 범죄수사연구원, 2020, 130면.

49 대법원 2017. 9. 21. 선고 2015도12400 판결.

포트스캔이 공개적으로 응답하는 범위 내에서 제한적으로 이루어진 경우에는 절차적 위법성이 인정되기 어려워 증거능력이 부정되지 않을 수 있다.⁵⁰ 그러나 무분별한 대량 스캔이나 보호조치 우회를 수반한 경우에는 정보통신망 침입 또는 영장주의 위반으로 평가될 가능성이 있으며, 이 경우 해당 정보의 증거능력은 부정될 수 있다.⁵¹

한편 포트스캔을 통해 확보된 정보가 적법하게 수집되었다 하더라도,⁵² 형사재판에서 증거로 활용되기 위해서는 데이터의 무결성과 동일성이 확보되어야 한다. 이를 위해서는 수집 로그의 원본 보존, 해시값 생성, 타임스탬프 기록, 분석 절차의 문서화 등 체계적인 관리가 요구되며, 이는 증거의 신뢰성과 증명력을 뒷받침하는 핵심 요소가 된다.

결국 포트스캔 기반 정보의 증거능력은 수집 단계의 적법성뿐 아니라, 이후 관리·보존·분석 과정에서 무결성과 동일성이 확보되었는지 여부에 의해 종합적으로 판단된다.

V. 결론

본 연구는 포트스캔 기반 OSINT의 기술적 특성과 수사상 활용 가능성을 검토하고, 관련 법원칙과 판례를 중심으로 그 적법성 판단 기준을 분석하였다. 사이버범죄의 분산성과 은닉성으로 인해 전통적인 압수·수색 중심 수사에는 한계가 존재하며, 포트스캔은 범죄 인프라를 신속히 파악할 수 있는 초기 대응 수단으로 일정한 실무적 의의를 가진다. 다만 그 적법성은 기술적 유용성만으로 정당화될 수 없고, 행위의 방식과 범위에 따라 개별적으로 평가되어야 한다.

검토 결과, 포트스캔의 적법성은 단일 기준이 아닌 복합적 요소에 의해 판단된다. 정보통신망법상 침입 여부는 보호조치 우회 및 접근 범위 초과 여부를 중심으로 판단되며, 공개 포트에 대한 제한적 확인은 일반적으로 침입행위와 구별될 수 있으나 인증 우회 등 적극적 접근이 수반되는 경우 위법성이 인정될 수 있다. 또한 형법상 정당행위 여부는 공익성, 필요성, 상당성, 침해 최소성 및 절차적 통제를 종합적으로 고려하여 판단되어야 한다.

형사소송법적 관점에서 포트스캔은 그 단계와 정보의 성격에 따라 임의수사와 강제처분 사이에 위치하는 행위로 평가된다. 단순한 포트 상태 확인은 압수·수색과 구별될 수 있으나, 배너 수집이나 내부 구조 탐색 등으로 확장되는 경우 수색적 성격이 강화되어 보다 엄격한 통제가 요구된다. 또한

50 이도식, 사인이 위법하게 수집하거나 제공한 디지털증거의 증거능력 판단기준 정립시도, 서울대학교 대학원 석사학위논문, 2024, 32면.

51 이윤제, 위법수집증거배제법칙, 아주대학교 대학원 석사학위논문, 2012, 16면.

52 Fortinet, "What is a port scan? How to prevent port scan attacks?," Fortinet Cyber Glossary, 2025. <https://www.fortinet.com/resources/cyberglossary/what-is-port-scan>, (검색 2026. 3. 3.).

증거 활용 가능성은 수집 경위의 적법성과 절차적 통제 여부에 따라 달라지며, 기록성·무결성 확보가 중요하다.

비교법적으로, 미국은 공개성과 접근 가능성을 기준으로 임의수사의 범위를 설정하면서도 데이터 집적에 따른 침해 위험을 내부 통제로 관리하고, 유럽은 비례성 및 데이터 보호 원칙을 제도적으로 통합하고 있다. 이는 국내에서도 포트스캔을 단순한 기술 문제가 아니라 공개성, 비례성, 절차적 통제, 증거화 가능성을 종합적으로 고려하는 규범적 틀 속에서 이해할 필요가 있음을 시사한다.

본 연구는 포트스캔을 ‘비침입적 탐지행위’로 재구성하고, 공개성, 침해성, 자동화 수준, 정보 결합 가능성 및 절차적 통제를 중심으로 한 구조화된 판단 기준을 제시하였다는 점에서 의의를 가진다. 나아가 기술적 행위 유형과 법적 효과를 연계한 분석 틀을 통해, 포트스캔의 적법성 판단을 실무 적용 가능한 수준으로 구체화하였다는 점에서 독자적 기여를 가진다.

ACCEPTANCE INFO

논문접수: 2026. 3. 17. / 심사개시: 2026. 3. 18. / 게재확정: 2026. 4. 10.

참고문헌

I. 단행본

1. 국외 문헌

- Convention on Cybercrime (Budapest Convention), Council of Europe European Treaty Series – No. 185, Budapest, Hungary, 23 Nov. 2001.
- Europol, Internet Organised Crime Threat Assessment (IOCTA) 2024, Luxembourg: Publications Office of the European Union, Jul. 2024.
- Europol, OSINT Monitoring, Public Document, The Hague, NL, 14 Feb. 2025.
- Matherly, J., “Complete Guide to Shodan,” Shodan LLC, 2018.
- International Criminal Police Organization – INTERPOL, INTERPOL Africa Cyberthreat Assessment Report 2025, Lyon, France: INTERPOL, 2025.
- INTERPOL, “Constitution of the International Criminal Police Organization-INTERPOL,” Art. 2,3, 1956.
- OSCE (Organization for Security and Co-operation in Europe), Guidelines on Cybercrime Investigation, Sep. 18, 2015.
- Privacy and Civil Liberties Oversight Board, Use of Open Source Information by the Federal Bureau of Investigation, Staff Report, Washington, DC, USA, Nov. 20, 2025.
- Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation), Official Journal of the European Union, L 119, 4 May 2016.
- U.S. Department of Justice, Office of Justice Programs, Bureau of Justice Assistance, Real-Time and Open Source Analysis (ROSA) Resource Guide. Washington, DC, USA: BJA, 2017.

II. 논문

1. 국내 논문

- 강길안, 공개정보(OSINT)의 수사절차에서의 활용 범위와 한계, 법과학의 신동향, 제11호, 대검찰청, 2025.
- 강철하·강윤정, 디지털 포렌식에서 디지털증거의 특성과 법적 쟁점, 법학논총, 제19권 제3호, 조선대학교 법학연구원, 2012.
- 김경한 외, OSINT기반의 활용 가능한 사이버 위협 인텔리전스 생성을 위한 위협 정보 수집 시스템, Review of KIISC, 제29권 제6호, 한국정보보호학회, 2019.
- 김진환 외, 불법 사이트 사건 사례를 통한 데이터베이스 증거물 획득 방안, 디지털포렌식연구, 제4권 제2호, 한국디지털포렌식학회, 2010.

- 김학경, 경찰의 온라인 공개개인정보 활용에 관한 법적 검토, 형사정책연구, 제35권 제1호, 한국형사법무정책연구원, 2024.
- 노소형·지성우, 디지털 증거의 긴급한 보전을 위한 법제 개선 연구, 한국IT서비스학회지, 제19권 제3호, 한국IT서비스학회, 2020.
- 박웅신, 다크웹상 범죄정보 자동 수집·분석 플랫폼 도입의 고려사항 연구, 형사정책, 제35권 제3호, 한국형사정책학회, 2023.
- 박현민 외, 보이스피싱 심박스 분석 및 수사활용 방안에 관한 연구, 디지털포렌식연구, 제16권 제3호, 한국디지털포렌식학회, 2022.
- 안성수, 디지털 증거의 증거능력, 법조, 제66권 제1호, 사단법인 법조협회, 2017.
- 앤소니 온체 외, 사이버수사에서 귀속문제 의사결정을 위한 공개출처정보 처리 자동화, 디지털포렌식연구, 제15권 제2호, 한국디지털포렌식학회, 2021.
- 유인재 외, IP 포트 스캐닝을 이용한 불법 유통 플랫폼 추적 방법, 소프트웨어포렌식 논문지, 제19권 제4호, 한국소프트웨어감정평가학회, 2023.
- 이경열·박제민, 역의 압수·수색 수사에 관한 한일 최고법원판례 비교연구, 비교형사법연구, 제24권 제3호, 한국비교형사법학회, 2022.
- 이관희, 디지털 저장매체에서 Plain View 원칙을 적용하기 위한 조건 - 미 연방판례를 중심으로 -, 범죄수사학연구, 제6권 제2호, 경찰대학 범죄수사연구원, 2020.
- 이도식, 사인이 위법하게 수집하거나 제공한 디지털증거의 증거능력 판단기준 정립시도, 서울대학교 대학원 석사학위논문, 2024.
- 이윤제, 위법수집증거배제법칙, 아주대학교 대학원 석사학위논문, 2012.
- 이후기 외, 랜섬웨어 분석 및 탐지패턴 자동화 모델에 관한 연구, 한국정보통신학회논문지, 제21권 제8호, 한국정보통신학회, 2017.
- 조상덕, 보안취약점 진단을 활용한 보안관제 고도화에 관한 연구, 건국대학교 정보통신대학원 석사학위논문, 2014.
- 조성훈, 주거침입과 정보통신망침입: 보호법익과 ‘침입’의 해석론을 중심으로, 선진상사법률연구, 제80호, 법무부, 2017.
- 하태인, 형사소송법 제308조의2(위법수집증거배제법칙)의 해석, 형사정책연구, 제25권 제4호, 한국형사법무정책연구원, 2014.

III. 기타

1. 국내 판례

- 대법원 2005. 4. 15. 선고 2004도5372 판결.
- 대법원 2005. 4. 29. 선고 2005도870 판결.
- 대법원 2011. 5. 26. 선고 2009모1190 판결.
- 대법원 2017. 9. 21. 선고 2015도12400 판결.
- 대법원 2022. 7. 14. 선고 2022도3413 판결.
- 대법원 2023. 4. 27. 선고 2018도8161 판결.

2. 국외 판례

Riley v. California, 573 U.S. 373 (2014).

U.S. Supreme Court, Coolidge v. New Hampshire, 403 U.S. 1971.

3. 보고서

경찰청, 범죄수사규칙, 경찰청훈령 제1194호.

김학신, 디지털 범죄 수사와 기본권에 관한 연구, 책임연구보고서 2009-04, 치안정책연구소, 2009.

이호석 외, 2024.1Q KARA 랜섬웨어 동향 보고서, SK설더스, 2024.

탁희성, 형사절차상 digital evidence에 관한 연구, 형사정책연구원 연구총서 02-02, 한국형사법무정책연구원, 2002.

한국인터넷진흥원, 침해사고 조치 가이드, 2012.

한국정보보호진흥원, 네트워크 취약점 점검도구 선정 지침, 2002.

4. 국내 언론 보도 및 기타(인터넷 자료 포함)

임화섭, “구글, 사이버공격 악용 우려 中 기업 ‘IP아이디어’에 전쟁 선포”, 연합뉴스, 2026. 1. 29.
<https://www.yna.co.kr/view/AKR202601291508000009>, (검색 2026. 3. 3.).

5. 국외 언론 보도 및 기타(인터넷 자료 포함)

Censys, Censys documentation, 2026. <https://docs.censys.com/>, (검색 2026. 3. 3.).

Criminal IP, “Criminal IP: Cybersecurity search engine,” 2026. <https://CriminalIP.io>, (검색 2026. 3. 3.).

Fortinet, “What is a port scan? How to prevent port scan attacks?,” Fortinet Cyber Glossary, 2025. <https://www.fortinet.com/resources/cyberglossary/what-is-port-scan>, (검색 2026. 3. 3.).

A Study on the Technical Characteristics of Port Scan-Based Open Source Intelligence (OSINT) Collection and the Factors for Assessing Investigative Legality

Youngkook Kim* · Doowon Jeong**

* First Author. Investigation Division, Songpa Police Station, Seoul Metropolitan Police Agency / The Master's Course, Sungkyunkwan University

**Corresponding Author. Associate Professor, Dept. of Scientific Investigation, Sungkyunkwan University

ABSTRACT

Recent cybercrime presents structural challenges for conventional search-and-seizure-based investigations because criminal infrastructures are increasingly distributed, concealed, and virtualized. In this context, port-scan-based open source intelligence can serve as an information-gathering means for identifying criminal infrastructure exposed on public networks and for setting the direction of subsequent investigations. However, it remains unclear whether port scanning should be regarded as a mere confirmation of publicly exposed information or as unlawful information gathering or unauthorized access under the Act on Promotion of Information and Communications Network Utilization and Information Protection. This study distinguishes between the technical characteristics of active port scanning and passive searches based on external platforms, and examines the factors relevant to assessing investigative legality in light of legal principles and case law, including unauthorized access, justifiable act, and the warrant requirement in criminal procedure. The analysis shows that the key factors include whether protective measures are bypassed, the scope of authorized access, the proportionality of the intensity and range of the scan, and the differentiated stages of information acquisition. These findings suggest a useful reference framework for discussing the permissible scope and limits of port-scan-based investigation in practice.

KEYWORD

port scanning, open source intelligence, legality, cyber investigation, warrant requirement, unauthorized access